

중고거래 플랫폼 개발 명세서 및 시큐어 코딩 점검 체크리스트

1. 프로젝트 개요

1.1 프로젝트명

중고거래 및 사용자 소통 플랫폼

1.2 프로젝트 목적

사용자가 회원가입과 로그인을 통해 플랫폼을 이용하고, 중고 상품을 등록·조회·관리할 수 있는 웹 서비스를 개발한다.

사용자는 전체 채팅과 1대1 채팅을 통해 다른 사용자와 소통할 수 있으며, 불량 사용자 또는 부적절한 상품을 신고할 수 있다.

신고가 일정 횟수 이상 누적된 상품은 차단 또는 삭제하고, 신고가 누적된 사용자는 휴면 계정으로 전환하여 안전한 플랫폼 이용 환경을 제공한다.

1.3 주요 개발 목표

- 사용자 회원가입 및 로그인 기능 구현
- 사용자 프로필 및 마이페이지 기능 구현
- 상품 등록, 조회, 수정, 삭제 기능 구현
- 전체 채팅 및 1대1 채팅 기능 구현
- 사용자 및 상품 신고 기능 구현
- 신고 누적에 따른 상품 차단 및 사용자 휴면 처리
- 사용자 정보와 상품 정보를 데이터베이스로 관리
- 시큐어 코딩 원칙을 적용하여 주요 웹 취약점 예방

2. 사용자 유형

2.1 비회원

비회원은 다음 기능을 이용할 수 있다.

- 메인 페이지 접속
- 등록된 상품 목록 조회
- 상품 상세 정보 조회
- 회원가입
- 로그인

비회원은 상품 등록, 채팅, 신고 등의 기능을 이용할 수 없다.

2.2 일반 회원

일반 회원은 다음 기능을 이용할 수 있다.

- 로그인 및 로그아웃
- 사용자 프로필 조회
- 자신의 소개글 수정
- 자신의 비밀번호 변경
- 상품 등록
- 자신이 등록한 상품 수정 및 삭제
- 전체 상품 조회
- 상품 상세 조회
- 전체 채팅 참여
- 다른 사용자와 1대1 채팅
- 불량 상품 신고
- 불량 사용자 신고

2.3 휴면 회원

신고가 일정 횟수 이상 누적된 사용자는 휴면 상태로 전환된다.

휴면 회원은 다음 기능을 제한받는다.

- 로그인 제한
- 상품 등록 제한
- 상품 수정 및 삭제 제한
- 채팅 이용 제한
- 신고 기능 제한

2.4 관리자

관리자는 다음 기능을 수행할 수 있다.

- 전체 사용자 조회
 - 사용자 상태 확인
 - 사용자 휴면 처리 및 해제
 - 신고 내역 조회
 - 신고된 상품 확인
 - 불량 상품 차단 및 삭제
 - 신고 기준 횟수 설정
 - 부적절한 채팅 또는 사용자 활동 확인
-

3. 기능 요구사항

3.1 회원가입 기능

기능 설명

사용자가 플랫폼 이용을 위한 계정을 생성한다.

입력 항목

- 사용자 아이디
- 사용자 계정명 또는 닉네임
- 비밀번호
- 비밀번호 확인
- 소개글

처리 조건

- 사용자 아이디는 중복될 수 없다.
- 사용자 계정명 또는 닉네임의 중복 허용 여부는 정책으로 결정한다.
- 비밀번호와 비밀번호 확인 값이 일치해야 한다.
- 비밀번호는 안전한 형식 조건을 만족해야 한다.
- 비밀번호를 평문으로 데이터베이스에 저장하면 안 된다.
- 사용자 입력값에 대한 길이, 형식 및 허용 문자 검증이 필요하다.
- 회원가입 완료 시 일반 회원 상태로 등록한다.

예외 처리

- 중복 아이디 입력
- 필수 항목 누락
- 허용되지 않은 문자 입력
- 비밀번호 정책 미충족
- 비밀번호 확인 불일치
- 데이터베이스 저장 실패

3.2 로그인 기능

기능 설명

등록된 사용자가 아이디와 비밀번호를 이용하여 인증한다.

입력 항목

- 사용자 아이디
- 비밀번호

처리 조건

- 입력된 아이디와 비밀번호를 검증한다.

- 저장된 비밀번호 해시와 입력 비밀번호를 안전하게 비교한다.
- 로그인 성공 시 인증 세션 또는 인증 토큰을 발급한다.
- 휴면 계정은 로그인할 수 없도록 제한한다.
- 로그인 실패 횟수가 지나치게 많으면 일정 시간 로그인을 제한한다.
- 로그인 성공 후 세션 식별자를 재발급한다.

예외 처리

- 존재하지 않는 사용자
 - 비밀번호 불일치
 - 휴면 계정
 - 로그인 시도 횟수 초과
 - 세션 생성 실패
-

3.3 로그아웃 기능

기능 설명

현재 로그인된 사용자의 인증 상태를 종료한다.

처리 조건

- 서버 세션을 무효화한다.
 - 클라이언트에 저장된 인증 쿠키 또는 토큰을 삭제한다.
 - 로그아웃 이후 인증이 필요한 페이지에 접근하지 못하도록 한다.
-

3.4 사용자 프로필 조회 기능

기능 설명

플랫폼 사용자의 기본 프로필을 확인한다.

표시 항목

- 사용자 계정명
- 소개글
- 가입일
- 계정 상태
- 등록된 상품 목록

보안 조건

다음과 같은 민감한 정보는 다른 사용자에게 공개하지 않는다.

- 비밀번호 및 비밀번호 해시
- 로그인 실패 횟수
- 내부 사용자 식별 정보
- 세션 정보

- 관리자 메모
-

3.5 마이페이지 기능

기능 설명

사용자가 자신의 정보를 조회하고 수정한다.

제공 기능

- 사용자 아이디 확인
- 사용자 계정명 확인
- 소개글 조회 및 수정
- 비밀번호 변경
- 자신이 등록한 상품 조회
- 자신이 작성한 신고 내역 조회
- 자신의 계정 상태 확인

비밀번호 변경 조건

- 현재 비밀번호를 먼저 확인한다.
 - 새로운 비밀번호는 비밀번호 정책을 만족해야 한다.
 - 기존 비밀번호와 같은 비밀번호를 제한할 수 있다.
 - 비밀번호 변경 후 기존 세션을 종료하거나 재인증하도록 한다.
-

4. 상품 관리 기능

4.1 상품 등록 기능

기능 설명

로그인한 사용자가 판매할 상품을 등록한다.

입력 항목

- 상품명
- 상품 설명
- 가격
- 상품 사진
- 상품 상태
- 등록 시간

처리 조건

- 로그인한 사용자만 상품을 등록할 수 있다.
- 판매자 아이디는 로그인 정보에서 가져온다.
- 클라이언트가 전달한 판매자 아이디를 그대로 신뢰하면 안 된다.
- 상품명과 상품 설명은 길이를 제한한다.

- 가격은 0 이상의 숫자만 허용한다.
- 상품 사진은 허용된 확장자와 MIME 형식만 등록할 수 있다.
- 파일명은 서버에서 임의의 이름으로 변경하여 저장한다.
- 상품 등록 시 기본 상태는 판매 중으로 설정한다.

상품 상태 예시

- 판매 중
 - 예약 중
 - 판매 완료
 - 차단
 - 삭제
-

4.2 전체 상품 조회 기능

기능 설명

등록된 상품을 목록 형태로 조회한다.

목록 표시 항목

- 상품 이름
- 대표 이미지
- 가격
- 판매 상태
- 등록 시간

처리 조건

- 기본 상품 목록에서는 상품 이름 중심으로 간단하게 표시한다.
 - 사용자가 상품을 클릭하면 상품 상세 페이지로 이동한다.
 - 차단 또는 삭제된 상품은 일반 사용자에게 표시하지 않는다.
 - 페이지네이션을 적용하여 한 번에 지나치게 많은 상품을 불러오지 않는다.
 - 상품명 검색 기능을 추가할 수 있다.
-

4.3 상품 상세 조회 기능

기능 설명

선택한 상품의 자세한 정보를 보여준다.

표시 항목

- 상품명
- 상품 사진
- 상품 설명
- 가격
- 판매자 계정명

- 상품 상태
- 등록 일시
- 신고 버튼
- 판매자와 1대1 채팅 버튼

처리 조건

- 존재하지 않는 상품에 접근하면 오류 페이지를 표시한다.
 - 차단되거나 삭제된 상품은 일반 사용자에게 노출하지 않는다.
 - 판매자의 내부 사용자 아이디나 민감한 개인정보는 노출하지 않는다.
 - 상품 설명에 포함된 스크립트 코드가 실행되지 않도록 출력값을 이스케이프한다.
-

4.4 등록 상품 관리 기능

기능 설명

사용자가 자신이 등록한 상품을 확인하고 관리한다.

제공 기능

- 등록 상품 목록 조회
- 상품 정보 수정
- 상품 삭제
- 판매 상태 변경

권한 조건

- 상품을 등록한 사용자만 수정하거나 삭제할 수 있다.
 - URL의 상품 아이디만 변경하여 다른 사람의 상품을 수정할 수 없어야 한다.
 - 서버에서 로그인 사용자와 상품 판매자가 같은지 반드시 검증한다.
 - 관리자는 정책에 따라 모든 상품을 차단하거나 삭제할 수 있다.
-

4.5 상품 삭제 기능

기능 설명

상품 등록자 또는 관리자가 상품을 삭제한다.

처리 조건

- 일반 사용자는 자신이 등록한 상품만 삭제할 수 있다.
 - 삭제 전에 사용자 확인 절차를 제공한다.
 - 삭제된 상품은 즉시 조회 목록에서 제외한다.
 - 필요하면 실제 데이터를 바로 제거하지 않고 삭제 상태로 변경하는 소프트 삭제를 적용한다.
 - 상품 삭제 기록을 로그로 남긴다.
-

5. 사용자 소통 기능

5.1 전체 채팅 기능

기능 설명

로그인한 모든 사용자가 참여할 수 있는 공용 채팅방을 제공한다.

표시 항목

- 작성자 계정명
- 메시지 내용
- 작성 시간

처리 조건

- 로그인한 사용자만 메시지를 작성할 수 있다.
 - 메시지 최대 길이를 제한한다.
 - HTML 및 JavaScript 코드가 실행되지 않도록 처리한다.
 - 일정 시간 동안 전송 가능한 메시지 수를 제한한다.
 - 부적절한 메시지를 신고할 수 있도록 확장할 수 있다.
 - 휴면 사용자는 채팅 기능을 사용할 수 없다.
-

5.2 1대1 채팅 기능

기능 설명

두 명의 사용자가 개별 채팅방을 통해 소통한다.

처리 조건

- 로그인한 사용자만 이용할 수 있다.
 - 채팅 참여자만 해당 채팅방의 메시지를 조회할 수 있다.
 - URL의 채팅방 번호를 변경하여 다른 사용자의 채팅을 조회할 수 없어야 한다.
 - 채팅방 생성 시 참여자 정보를 서버에서 검증한다.
 - 자신과의 채팅방 생성을 제한할 수 있다.
 - 차단 또는 휴면 상태인 사용자는 새 채팅을 생성하지 못하도록 한다.
-

6. 신고 및 악성 사용자 필터링 기능

6.1 신고 기능

기능 설명

로그인한 사용자가 불량 상품 또는 불량 사용자를 신고한다.

신고 대상

- 상품
- 사용자

입력 항목

- 신고 대상
- 신고 유형
- 신고 사유
- 신고 일시

신고 유형 예시

- 허위 상품
- 부적절한 상품
- 사기 의심
- 욕설 또는 비방
- 도배
- 불법 거래
- 기타

처리 조건

- 로그인한 사용자만 신고할 수 있다.
- 신고 사유를 필수로 입력하게 한다.
- 신고 사유의 최소 및 최대 길이를 제한한다.
- 사용자가 동일 대상을 반복 신고하는 행위를 제한한다.
- 자신이 등록된 상품 또는 자신의 계정을 신고하지 못하도록 할 수 있다.
- 신고 횟수는 단순 요청값이 아니라 실제 신고 데이터로 계산한다.

6.2 불량 상품 차단 기능

기능 설명

상품 신고가 일정 횟수 이상 누적되면 해당 상품을 차단한다.

처리 조건

- 신고 횟수 기준은 관리자가 설정한다.
 - 동일 사용자의 중복 신고는 신고 횟수에 한 번만 반영한다.
 - 기준 횟수 이상 신고된 상품은 차단 상태로 변경한다.
 - 차단된 상품은 일반 상품 목록과 상세 페이지에서 노출하지 않는다.
 - 관리자가 신고 내용을 검토한 후 삭제 여부를 결정할 수 있다.
 - 자동 차단과 관리자 검토 상태를 구분할 수 있다.
-

6.3 불량 사용자 휴면 처리 기능

기능 설명

사용자 신고가 일정 횟수 이상 누적되면 해당 사용자를 휴면 계정으로 전환한다.

처리 조건

- 신고 횟수 기준은 관리자가 설정한다.
 - 동일 신고자의 중복 신고는 한 번만 반영한다.
 - 휴면 계정으로 전환되면 로그인을 제한한다.
 - 이미 로그인된 세션은 종료한다.
 - 상품 등록 및 채팅 기능을 제한한다.
 - 관리자가 신고 내용을 검토한 후 휴면 상태를 해제할 수 있다.
 - 휴면 처리와 해제 기록을 관리 로그에 저장한다.
-

7. 웹페이지 설계

7.1 기본 페이지

주요 구성 요소

- 서비스 이름 및 로고
- 회원가입 버튼
- 로그인 버튼
- 전체 상품 목록
- 상품 검색 영역
- 전체 채팅 영역
- 최근 등록 상품
- 신고 안내
- 로그인 사용자 메뉴

디자인 방향

- 단순하고 직관적인 레이아웃
 - 카드 형태의 상품 목록
 - 과도한 색상 사용을 피한 기본 디자인
 - 모바일과 데스크톱에서 사용할 수 있는 반응형 디자인
 - 버튼과 입력창의 상태가 명확하게 구분되는 디자인
-

7.2 회원가입 페이지

구성 요소

- 사용자 아이디 입력란
- 아이디 중복 확인 버튼
- 사용자 계정명 입력란

- 비밀번호 입력란
 - 비밀번호 확인 입력란
 - 소개글 입력란
 - 가입 버튼
 - 로그인 페이지 이동 링크
-

7.3 로그인 페이지

구성 요소

- 사용자 아이디 입력란
 - 비밀번호 입력란
 - 로그인 버튼
 - 회원가입 페이지 이동 링크
 - 로그인 실패 메시지
-

7.4 전체 상품 조회 및 채팅 페이지

구성 요소

- 상품 목록
 - 상품 검색창
 - 상품 카드
 - 상품 상세 페이지 이동 기능
 - 전체 채팅 메시지 목록
 - 채팅 메시지 입력창
 - 메시지 전송 버튼
-

7.5 새 상품 등록 페이지

구성 요소

- 상품명 입력란
 - 상품 설명 입력란
 - 가격 입력란
 - 상품 사진 업로드
 - 등록 버튼
 - 취소 버튼
-

7.6 상품 상세 조회 페이지

구성 요소

- 상품명
- 상품 이미지

- 상품 설명
- 가격
- 판매자 계정명
- 판매 상태
- 판매자와 채팅하기 버튼
- 상품 신고 버튼
- 수정 및 삭제 버튼

수정 및 삭제 버튼은 상품 등록자에게만 표시한다.

7.7 마이페이지

구성 요소

- 사용자 아이디
- 사용자 계정명
- 소개글
- 소개글 수정 버튼
- 비밀번호 변경 기능
- 자신이 등록한 상품 목록
- 상품 수정 및 삭제 기능
- 신고 내역
- 로그아웃 버튼

7.8 신고 페이지

구성 요소

- 신고 대상 정보
- 신고 유형 선택
- 신고 사유 입력란
- 신고 제출 버튼
- 취소 버튼

8. 데이터베이스 설계

8.1 사용자 테이블: users

필드명	자료형 예시	제약조건	설명
user_id	BIGINT	PK, AUTO INCREMENT	내부 사용자 식별자
login_id	VARCHAR(50)	UNIQUE, NOT NULL	로그인에 사용하는 아이디
account_name	VARCHAR(50)	NOT NULL	사용자 계정명 또는 닉네임
password_hash	VARCHAR(255)	NOT NULL	해시 처리된 비밀번호

필드명	자료형 예시	제약조건	설명
introduction	VARCHAR(500)	NULL	사용자 소개글
account_status	VARCHAR(20)	NOT NULL	ACTIVE, DORMANT, WITHDRAWN
failed_login_count	INT	DEFAULT 0	로그인 실패 횟수
locked_until	DATETIME	NULL	로그인 제한 종료 시간
created_at	DATETIME	NOT NULL	가입 일시
updated_at	DATETIME	NOT NULL	수정 일시

비밀번호는 `password` 가 아닌 `password_hash` 필드에 해시값으로 저장한다.

8.2 상품 테이블: products

필드명	자료형 예시	제약조건	설명
product_id	BIGINT	PK, AUTO INCREMENT	상품 식별자
seller_id	BIGINT	FK, NOT NULL	판매자 사용자 식별자
product_name	VARCHAR(100)	NOT NULL	상품명
product_description	TEXT	NOT NULL	상품 설명
price	DECIMAL	NOT NULL	상품 가격
image_path	VARCHAR(255)	NULL	상품 이미지 저장 경로
product_status	VARCHAR(20)	NOT NULL	판매 중, 판매 완료, 차단, 삭제
report_count	INT	DEFAULT 0	신고 횟수 캐시
created_at	DATETIME	NOT NULL	상품 등록 일시
updated_at	DATETIME	NOT NULL	상품 수정 일시

`report_count` 는 빠른 조회를 위해 사용할 수 있지만, 실제 신고 여부는 신고 테이블 데이터를 기준으로 검증해야 한다.

8.3 신고 테이블: reports

필드명	자료형 예시	제약조건	설명
report_id	BIGINT	PK, AUTO INCREMENT	신고 식별자
reporter_id	BIGINT	FK, NOT NULL	신고자 사용자 식별자
target_type	VARCHAR(20)	NOT NULL	USER 또는 PRODUCT
target_user_id	BIGINT	FK, NULL	신고 대상 사용자

필드명	자료형 예시	제약조건	설명
target_product_id	BIGINT	FK, NULL	신고 대상 상품
report_category	VARCHAR(50)	NOT NULL	신고 유형
report_reason	VARCHAR(1000)	NOT NULL	신고 사유
report_status	VARCHAR(20)	NOT NULL	접수, 검토 중, 승인, 반려
created_at	DATETIME	NOT NULL	신고 일시
reviewed_at	DATETIME	NULL	관리자 검토 일시

신고 테이블 제약조건

- 상품 신고라면 target_product_id 만 사용한다.
- 사용자 신고라면 target_user_id 만 사용한다.
- 동일 사용자가 같은 대상을 중복 신고하지 못하도록 복합 UNIQUE 제약조건을 설정한다.
- 클라이언트가 전달한 신고자 아이디를 신뢰하지 않고 로그인 세션에서 확인한다.

8.4 전체 채팅 테이블: global_messages

필드명	자료형 예시	제약조건	설명
message_id	BIGINT	PK, AUTO INCREMENT	메시지 식별자
sender_id	BIGINT	FK, NOT NULL	작성자
message_content	VARCHAR(1000)	NOT NULL	메시지 내용
message_status	VARCHAR(20)	NOT NULL	정상, 숨김, 삭제
created_at	DATETIME	NOT NULL	작성 시간

8.5 1대1 채팅방 테이블: chat_rooms

필드명	자료형 예시	제약조건	설명
room_id	BIGINT	PK, AUTO INCREMENT	채팅방 식별자
user1_id	BIGINT	FK, NOT NULL	첫 번째 사용자
user2_id	BIGINT	FK, NOT NULL	두 번째 사용자
product_id	BIGINT	FK, NULL	관련 상품
created_at	DATETIME	NOT NULL	채팅방 생성 시간

동일한 두 사용자와 동일 상품에 대한 채팅방이 중복 생성되지 않도록 제약조건을 설정할 수 있다.

8.6 1대1 채팅 메시지 테이블: direct_messages

필드명	자료형 예시	제약조건	설명
message_id	BIGINT	PK, AUTO INCREMENT	메시지 식별자
room_id	BIGINT	FK, NOT NULL	채팅방 식별자
sender_id	BIGINT	FK, NOT NULL	메시지 작성자
message_content	VARCHAR(1000)	NOT NULL	메시지 내용
is_read	BOOLEAN	DEFAULT FALSE	읽음 여부
created_at	DATETIME	NOT NULL	전송 시간

8.7 관리 로그 테이블: audit_logs

필드명	자료형 예시	제약조건	설명
log_id	BIGINT	PK, AUTO INCREMENT	로그 식별자
actor_id	BIGINT	FK, NULL	작업 수행 사용자 또는 관리자
action_type	VARCHAR(50)	NOT NULL	수행 작업
target_type	VARCHAR(30)	NULL	사용자, 상품, 신고 등
target_id	BIGINT	NULL	대상 식별자
description	VARCHAR(1000)	NULL	작업 상세 내용
ip_address	VARCHAR(45)	NULL	요청 IP
created_at	DATETIME	NOT NULL	작업 시간

9. 비기능 요구사항

9.1 보안성

- 모든 비밀번호는 안전한 알고리즘으로 해시하여 저장한다.
- SQL Injection을 방지하기 위해 ORM 또는 Prepared Statement를 사용한다.
- 모든 사용자 입력값을 서버에서 검증한다.
- 출력값을 이스케이프하여 XSS를 방지한다.
- 상태 변경 요청에는 CSRF 방어를 적용한다.
- 인증이 필요한 기능에는 서버 측 인증 검사를 적용한다.
- 객체별 접근 권한을 서버에서 검사한다.
- 파일 업로드 기능에는 확장자, MIME 형식, 파일 크기 검사를 적용한다.
- 중요 작업과 관리자 작업을 로그로 남긴다.

9.2 성능

- 상품 목록에는 페이지네이션을 적용한다.
- 자주 검색되는 필드에는 인덱스를 설정한다.
- 이미지 파일 크기를 제한한다.
- 채팅 메시지는 필요한 범위만 조회한다.
- 데이터베이스 연결을 적절하게 관리한다.

9.3 사용성

- 오류 메시지는 사용자가 이해하기 쉽게 표시한다.
- 필수 입력 항목을 명확히 표시한다.
- 상품 등록과 신고 과정이 복잡하지 않아야 한다.
- 모바일 환경에서도 사용할 수 있어야 한다.

9.4 유지보수성

- 사용자, 상품, 채팅, 신고 기능을 모듈별로 분리한다.
- 환경설정과 비밀정보를 소스 코드에서 분리한다.
- 예외 처리를 공통 방식으로 관리한다.
- 데이터베이스 마이그레이션 기능을 사용한다.
- 주요 기능에 대한 테스트 코드를 작성한다.

10. 시큐어 코딩 점검 체크리스트

10.1 회원가입 및 사용자 입력 검증

- [] 사용자 아이디가 비어 있을 때 가입이 거부되는가?
- [] 사용자 아이디의 최소·최대 길이가 제한되는가?
- [] 사용자 아이디에 허용되지 않은 문자가 입력되지 않는가?
- [] 사용자 아이디의 중복 여부를 서버에서 확인하는가?
- [] 중복 확인 이후 실제 가입 시에도 중복 여부를 다시 확인하는가?
- [] 사용자 계정명의 길이를 제한하는가?
- [] 소개글의 최대 길이를 제한하는가?
- [] 모든 필수값을 서버에서 다시 검증하는가?
- [] HTML 태그 또는 스크립트 입력을 안전하게 처리하는가?
- [] 비정상적으로 긴 요청값을 차단하는가?
- [] 회원가입 요청에 과도한 반복 호출 방지 기능이 있는가?

10.2 비밀번호 보안

- [] 비밀번호를 평문으로 저장하지 않는가?
- [] bcrypt, scrypt, Argon2와 같은 비밀번호 전용 해시를 사용하는가?
- [] 비밀번호 해시에 사용자별 Salt가 적용되는가?
- [] 비밀번호가 로그에 출력되지 않는가?
- [] 비밀번호가 URL 쿼리 문자열에 포함되지 않는가?

- [] 비밀번호 입력창에 `type="password"` 가 적용되어 있는가?
 - [] 비밀번호의 최소 길이가 설정되어 있는가?
 - [] 지나치게 단순한 비밀번호를 제한하는가?
 - [] 비밀번호 변경 시 현재 비밀번호를 확인하는가?
 - [] 비밀번호 변경 후 기존 세션을 무효화하는가?
 - [] 비밀번호 비교 시 안전한 해시 검증 함수를 사용하는가?
-

10.3 로그인 및 인증

- [] 존재하지 않는 아이디와 잘못된 비밀번호에 유사한 오류 메시지를 제공하는가?
 - [] 로그인 실패 횟수를 제한하는가?
 - [] 무차별 대입 공격 방어가 적용되어 있는가?
 - [] 로그인 성공 후 세션 식별자를 재발급하는가?
 - [] 로그아웃 시 서버 세션이 무효화되는가?
 - [] 휴면 사용자의 로그인이 제한되는가?
 - [] 인증 쿠키에 `HttpOnly` 속성이 설정되어 있는가?
 - [] HTTPS 환경에서 쿠키에 `Secure` 속성이 설정되어 있는가?
 - [] 쿠키에 적절한 `SameSite` 속성이 적용되어 있는가?
 - [] 세션 만료 시간이 설정되어 있는가?
 - [] 인증이 필요한 페이지 접근 시 매번 서버에서 로그인 상태를 확인하는가?
-

10.4 접근 권한 및 인가

- [] 다른 사용자의 마이페이지를 수정할 수 없는가?
 - [] URL의 사용자 번호를 변경해도 다른 사용자의 정보를 수정할 수 없는가?
 - [] 다른 사용자가 등록한 상품을 수정할 수 없는가?
 - [] 다른 사용자가 등록한 상품을 삭제할 수 없는가?
 - [] 채팅방 참여자가 아닌 사용자가 메시지를 조회할 수 없는가?
 - [] 일반 사용자가 관리자 기능에 접근할 수 없는가?
 - [] 화면에서 버튼을 숨기는 것뿐 아니라 서버에서도 권한을 확인하는가?
 - [] 클라이언트가 전달한 사용자 아이디를 신뢰하지 않는가?
 - [] 로그인 세션의 사용자 정보와 요청 대상을 비교하는가?
 - [] 삭제·수정 요청마다 객체 소유권을 확인하는가?
-

10.5 SQL Injection 방어

- [] SQL문에 사용자 입력값을 문자열로 직접 연결하지 않는가?
 - [] ORM 또는 Prepared Statement를 사용하는가?
 - [] 로그인 기능에서 파라미터 바인딩을 사용하는가?
 - [] 상품 검색 기능에서 파라미터 바인딩을 사용하는가?
 - [] 신고 검색 기능에서 파라미터 바인딩을 사용하는가?
 - [] 정렬 기준과 컬럼 이름을 화이트리스트로 제한하는가?
 - [] 데이터베이스 계정에 최소 권한만 부여되어 있는가?
 - [] 데이터베이스 오류 내용이 사용자 화면에 그대로 노출되지 않는가?
-

10.6 XSS 방어

- [] 상품명 출력 시 HTML 이스케이프를 적용하는가?
 - [] 상품 설명 출력 시 HTML 이스케이프를 적용하는가?
 - [] 사용자 소개글 출력 시 HTML 이스케이프를 적용하는가?
 - [] 채팅 메시지 출력 시 HTML 이스케이프를 적용하는가?
 - [] 신고 사유 출력 시 HTML 이스케이프를 적용하는가?
 - [] `<script>` 태그가 입력되어도 실행되지 않는가?
 - [] 이벤트 속성 형태의 공격 코드가 실행되지 않는가?
 - [] 위험한 HTML을 허용해야 한다면 검증된 Sanitizer를 사용하는가?
 - [] 프론트엔드에서 `innerHTML` 사용을 최소화하는가?
 - [] Content Security Policy 적용을 검토했는가?
-

10.7 CSRF 방어

- [] 회원정보 수정 요청에 CSRF 토큰을 사용하는가?
 - [] 비밀번호 변경 요청에 CSRF 토큰을 사용하는가?
 - [] 상품 등록 요청에 CSRF 토큰을 사용하는가?
 - [] 상품 수정 요청에 CSRF 토큰을 사용하는가?
 - [] 상품 삭제 요청에 CSRF 토큰을 사용하는가?
 - [] 신고 등록 요청에 CSRF 토큰을 사용하는가?
 - [] 로그아웃 요청의 CSRF 위험을 검토했는가?
 - [] 중요한 상태 변경 기능에 GET 방식을 사용하지 않는가?
 - [] CSRF 토큰이 서버에서 검증되는가?
-

10.8 파일 업로드 보안

- [] 이미지 파일의 허용 확장자를 제한하는가?
 - [] 확장자뿐 아니라 MIME 형식도 검사하는가?
 - [] 파일 내용을 검사하여 실제 이미지인지 확인하는가?
 - [] 업로드 가능한 최대 파일 크기가 설정되어 있는가?
 - [] 원본 파일명을 그대로 사용하지 않는가?
 - [] 서버에서 임의의 안전한 파일명을 생성하는가?
 - [] `../` 와 같은 경로 조작 문자열을 제거하는가?
 - [] 업로드 파일을 실행 가능한 디렉터리에 저장하지 않는가?
 - [] 업로드된 SVG 등 스크립트 실행 가능 형식을 제한하는가?
 - [] 이미지가 아닌 실행 파일 업로드가 차단되는가?
 - [] 파일 접근 시 사용자 입력 경로를 직접 사용하지 않는가?
-

10.9 상품 기능 보안

- [] 상품 가격에 음수가 입력되지 않는가?
- [] 지나치게 큰 가격이 입력되지 않는가?
- [] 상품명과 설명 길이가 제한되는가?
- [] 상품 등록자의 아이디를 세션에서 가져오는가?
- [] 차단된 상품이 목록에 노출되지 않는가?

- [] 삭제된 상품의 상세 페이지에 접근할 수 없는가?
 - [] 상품 상태값을 사용자가 임의로 차단 또는 관리자 상태로 변경할 수 없는가?
 - [] 상품 수정 시 판매자 권한을 확인하는가?
 - [] 상품 삭제 시 판매자 또는 관리자 권한을 확인하는가?
 - [] 상품 삭제 기록을 남기는가?
-

10.10 채팅 기능 보안

- [] 로그인한 사용자만 채팅 메시지를 전송할 수 있는가?
 - [] 휴면 사용자의 채팅 전송이 차단되는가?
 - [] 메시지 최대 길이가 제한되는가?
 - [] 빈 메시지가 등록되지 않는가?
 - [] 채팅 메시지의 스크립트 코드가 실행되지 않는가?
 - [] 짧은 시간 동안 대량 메시지 전송이 제한되는가?
 - [] 사용자가 발신자 아이디를 임의로 변경할 수 없는가?
 - [] 1대1 채팅방 참여자만 채팅 내용을 조회할 수 있는가?
 - [] WebSocket 연결 시에도 사용자 인증을 확인하는가?
 - [] 연결이 종료되거나 세션이 만료되면 채팅 인증도 종료되는가?
 - [] 채팅 오류 내용에 서버 내부 정보가 포함되지 않는가?
-

10.11 신고 기능 보안

- [] 로그인한 사용자만 신고할 수 있는가?
 - [] 신고자 아이디를 로그인 세션에서 가져오는가?
 - [] 신고 사유가 필수 입력값인가?
 - [] 신고 사유의 최대 길이가 제한되는가?
 - [] 동일 사용자가 같은 대상을 중복 신고할 수 없는가?
 - [] 존재하지 않는 사용자나 상품을 신고할 수 없는가?
 - [] 자신의 계정 또는 상품 신고 정책이 적용되어 있는가?
 - [] 신고 횟수를 클라이언트 요청값으로 수정할 수 없는가?
 - [] 신고 수가 실제 신고 데이터와 일치하는가?
 - [] 자동 차단 기준이 서버에서 적용되는가?
 - [] 신고 횟수 조작을 방지하는 데이터베이스 제약조건이 있는가?
 - [] 관리자가 신고 승인·반려 내역을 확인할 수 있는가?
-

10.12 휴면 계정 및 상품 차단

- [] 신고 기준 횟수를 서버 설정으로 관리하는가?
- [] 상품 신고 기준 초과 시 상품 상태가 차단으로 변경되는가?
- [] 사용자 신고 기준 초과 시 계정 상태가 휴면으로 변경되는가?
- [] 휴면 처리된 사용자의 기존 세션이 종료되는가?
- [] 휴면 사용자의 상품 등록이 제한되는가?
- [] 휴면 사용자의 채팅 기능이 제한되는가?
- [] 상품 차단 및 사용자 휴면 처리 기록이 남는가?
- [] 관리자가 자동 처리 결과를 검토할 수 있는가?
- [] 관리자만 휴면 상태를 해제할 수 있는가?

- [] 신고 취소 또는 반려 시 신고 횟수가 정확하게 반영되는가?
-

10.13 오류 처리

- [] 서버 오류 화면에 스택 트레이스가 노출되지 않는가?
 - [] 데이터베이스 접속 정보가 오류 메시지에 포함되지 않는가?
 - [] 파일 시스템 경로가 사용자에게 노출되지 않는가?
 - [] 존재하지 않는 페이지에는 적절한 404 응답을 제공하는가?
 - [] 권한이 없는 요청에는 적절한 403 응답을 제공하는가?
 - [] 인증되지 않은 요청에는 적절한 401 응답을 제공하는가?
 - [] 내부 서버 오류에는 적절한 500 응답을 제공하는가?
 - [] 사용자에게 필요한 정보만 오류 메시지로 제공하는가?
 - [] 예외가 발생해도 중요한 데이터가 비정상적으로 변경되지 않는가?
-

10.14 로그 및 개인정보 보호

- [] 비밀번호가 로그에 기록되지 않는가?
 - [] 세션 토큰과 인증 토큰이 로그에 기록되지 않는가?
 - [] 개인정보를 필요 이상으로 수집하지 않는가?
 - [] 관리자 작업 기록을 남기는가?
 - [] 상품 삭제 기록을 남기는가?
 - [] 사용자 휴면 처리 기록을 남기는가?
 - [] 로그인 성공 및 실패 기록을 남기는가?
 - [] 로그 파일에 대한 접근 권한이 제한되어 있는가?
 - [] 로그에 저장되는 사용자 입력값을 안전하게 처리하는가?
 - [] 로그 보관 기간과 삭제 정책이 있는가?
-

10.15 서버 및 배포 환경

- [] 비밀 키를 소스 코드에 직접 작성하지 않았는가?
 - [] 데이터베이스 비밀번호를 환경변수로 관리하는가?
 - [] 개발용 디버그 모드가 운영 환경에서 비활성화되어 있는가?
 - [] 운영 환경에서 HTTPS를 사용하는가?
 - [] 사용하지 않는 포트가 외부에 공개되지 않았는가?
 - [] 관리자 페이지 접근이 보호되어 있는가?
 - [] 기본 관리자 계정과 비밀번호를 변경했는가?
 - [] 사용 중인 라이브러리에 알려진 취약점이 없는지 점검했는가?
 - [] 의존성 버전이 관리되고 있는가?
 - [] 데이터베이스 백업 및 복구 절차가 있는가?
-

11. 기능 테스트 체크리스트

11.1 회원가입 테스트

- [] 정상적인 정보로 회원가입이 가능한가?
- [] 중복 아이디로 가입할 수 없는가?
- [] 비밀번호 확인이 다른 가입이 거부되는가?
- [] 필수값을 입력하지 않으면 오류가 표시되는가?
- [] 너무 긴 소개글이 거부되는가?
- [] 가입한 비밀번호가 데이터베이스에 해시값으로 저장되는가?

11.2 로그인 테스트

- [] 올바른 아이디와 비밀번호로 로그인할 수 있는가?
- [] 잘못된 비밀번호로 로그인할 수 없는가?
- [] 존재하지 않는 사용자로 로그인할 수 없는가?
- [] 휴면 사용자가 로그인할 수 없는가?
- [] 로그아웃 후 인증 페이지에 접근할 수 없는가?

11.3 상품 테스트

- [] 로그인 사용자가 상품을 등록할 수 있는가?
- [] 비회원은 상품을 등록할 수 없는가?
- [] 상품 목록에 상품명에 표시되는가?
- [] 상품을 클릭하면 상세 페이지로 이동하는가?
- [] 판매자만 자신의 상품을 수정할 수 있는가?
- [] 판매자만 자신의 상품을 삭제할 수 있는가?
- [] 차단된 상품이 일반 사용자에게 보이지 않는가?

11.4 채팅 테스트

- [] 전체 채팅 메시지가 실시간으로 전달되는가?
- [] 로그인하지 않은 사용자는 메시지를 보낼 수 없는가?
- [] 1대1 채팅방의 두 사용자만 메시지를 볼 수 있는가?
- [] 다른 채팅방 번호로 변경하여 접근할 수 없는가?
- [] 메시지에 작성자와 작성 시간이 표시되는가?
- [] 채팅에 입력한 스크립트가 실행되지 않는가?

11.5 신고 테스트

- [] 사용자를 신고할 수 있는가?
- [] 상품을 신고할 수 있는가?
- [] 신고 사유를 입력하지 않으면 제출되지 않는가?
- [] 동일 사용자가 같은 대상을 중복 신고할 수 없는가?
- [] 신고 누적 기준 이상인 상품이 차단되는가?
- [] 신고 누적 기준 이상인 사용자가 휴면 처리되는가?
- [] 휴면 사용자의 기존 세션이 종료되는가?

12. 보안 테스트 예시

12.1 SQL Injection 테스트

다음과 같은 값을 로그인 아이디 또는 검색창에 입력해도 인증 우회나 데이터베이스 오류가 발생하지 않아야 한다.

```
' OR '1'='1
```

```
admin' --
```

12.2 XSS 테스트

상품명, 상품 설명, 소개글, 신고 사유 및 채팅창에 다음 값을 입력해도 스크립트가 실행되지 않아야 한다.

```
<script>alert('XSS')</script>
```

```
<img src=x onerror=alert('XSS')>
```

12.3 접근 권한 테스트

- 상품 수정 URL의 상품 번호를 다른 사용자의 상품 번호로 변경한다.
- 상품 삭제 요청의 상품 번호를 변경한다.
- 1대1 채팅방 번호를 다른 번호로 변경한다.
- 마이페이지 수정 요청의 사용자 번호를 변경한다.
- 일반 사용자로 관리자 페이지에 접근한다.

모든 요청은 서버에서 거부되어야 한다.

12.4 파일 업로드 테스트

- 실행 파일의 확장자를 이미지 확장자로 변경하여 업로드한다.
- 이중 확장자 파일을 업로드한다.
- 지나치게 큰 이미지 파일을 업로드한다.
- 파일명에 경로 이동 문자열을 포함한다.
- 스크립트가 포함될 수 있는 SVG 파일을 업로드한다.

허용되지 않은 파일은 모두 차단되어야 한다.

13. 권장 API 구성

HTTP Method	API 경로 예시	기능	인증
POST	/api/auth/register	회원가입	불필요
POST	/api/auth/login	로그인	불필요
POST	/api/auth/logout	로그아웃	필요
GET	/api/users/{id}	사용자 프로필 조회	선택
GET	/api/me	내 정보 조회	필요
PATCH	/api/me/profile	소개글 수정	필요
PATCH	/api/me/password	비밀번호 변경	필요
GET	/api/products	전체 상품 조회	불필요
POST	/api/products	상품 등록	필요
GET	/api/products/{id}	상품 상세 조회	불필요
PATCH	/api/products/{id}	상품 수정	필요
DELETE	/api/products/{id}	상품 삭제	필요
POST	/api/reports	사용자 또는 상품 신고	필요
GET	/api/chat/global/messages	전체 채팅 조회	필요
POST	/api/chat/global/messages	전체 메시지 작성	필요
POST	/api/chat/rooms	1대1 채팅방 생성	필요
GET	/api/chat/rooms/{id}	채팅방 정보 조회	필요
GET	/api/chat/rooms/{id}/messages	1대1 메시지 조회	필요
POST	/api/chat/rooms/{id}/messages	1대1 메시지 작성	필요
GET	/api/admin/reports	전체 신고 조회	관리자
PATCH	/api/admin/users/{id}/status	사용자 상태 변경	관리자
PATCH	/api/admin/products/{id}/status	상품 상태 변경	관리자

14. 개발 우선순위

1단계: 기본 사용자 기능

- 데이터베이스 연결
- 사용자 테이블 생성

- 회원가입
- 로그인
- 로그아웃
- 마이페이지
- 소개글 수정
- 비밀번호 변경

2단계: 상품 기능

- 상품 테이블 생성
- 상품 등록
- 전체 상품 조회
- 상품 상세 조회
- 상품 수정
- 상품 삭제
- 상품 이미지 업로드

3단계: 신고 기능

- 신고 테이블 생성
- 사용자 신고
- 상품 신고
- 중복 신고 방지
- 신고 횟수 계산
- 상품 자동 차단
- 사용자 휴면 처리

4단계: 채팅 기능

- 전체 채팅
- 1대1 채팅방
- 1대1 메시지
- 채팅 참여자 권한 검사
- 실시간 통신 적용

5단계: 관리자 및 보안 강화

- 관리자 신고 조회
 - 상품 차단 및 삭제
 - 사용자 휴면 및 해제
 - 감사 로그
 - 입력값 검증
 - CSRF 방어
 - 파일 업로드 보안
 - 보안 테스트
 - 예외 처리
-

15. 완료 기준

다음 조건을 모두 만족하면 프로젝트의 주요 기능이 완료된 것으로 판단한다.

- 회원가입 시 아이디 중복이 방지된다.
- 비밀번호가 안전하게 해시되어 저장된다.
- 로그인과 로그아웃이 정상적으로 동작한다.
- 사용자가 자신의 소개글과 비밀번호를 수정할 수 있다.
- 로그인한 사용자가 상품을 등록할 수 있다.
- 등록된 상품을 누구나 조회할 수 있다.
- 상품 등록자만 자신의 상품을 수정하거나 삭제할 수 있다.
- 상품 목록에서 상품을 선택하면 상세 페이지가 표시된다.
- 사용자가 전체 채팅과 1대1 채팅을 이용할 수 있다.
- 채팅방 참여자가 아닌 사용자는 대화 내용을 볼 수 없다.
- 상품과 사용자를 신고할 수 있다.
- 동일 사용자의 중복 신고가 방지된다.
- 신고 기준 이상인 상품은 차단된다.
- 신고 기준 이상인 사용자는 휴면 처리된다.
- SQL Injection, XSS, CSRF 및 접근 권한 취약점에 대한 방어가 적용된다.
- 상품 이미지 업로드에 대한 보안 검사가 적용된다.
- 관리자와 주요 사용자 활동이 로그로 기록된다.